

Mapa de amenazas de Librería Fiordo

PF1495 · Hacking Ético en Aplicativos Web

Módulo 2 · MA03807 · Introducción al hacking ético

MODALIDAD

Grupal, de 4 a 5 personas.

APRENDIZAJE ESPERADO 1

Distinguir los conceptos fundamentales de la ciberseguridad, tipos de amenaza, ciberatacantes e impactos para el negocio acorde las buenas prácticas y estándares de la industria

CRITERIOS DE EVALUACIÓN

- 1.1 Define los términos clave de ciberseguridad y hacking ético acorde las buenas prácticas y estándares de la industria.
- 1.2 Describe los principales tipos de amenazas y vulnerabilidades comunes en aplicativos web según las buenas prácticas de la industria.
- 1.3 Explica los distintos tipos de ciberatacantes diferenciando entre hackers éticos y no éticos acorde las buenas prácticas de la industria.
- 1.4 Ejemplifica casos de vulnerabilidades y sus posibles impactos en la organización

Contexto

Librería Fiordo (empresa ficticia) vende libros en su tienda web: catálogo con buscador, reseñas de clientes, cuentas de usuario, carro de compras, pago con un proveedor externo y un panel de administración. La librería contrató a su equipo para probar la seguridad de la tienda, con autorización y un alcance acordado. En cada ABPRO del módulo, el equipo avanza en la preparación de esa prueba.

Problema

La gerencia intuye que «algo podría pasar», pero no sabe qué ni cuánto le costaría. Ya hubo señales: un correo falso que imitó al proveedor de pagos, reseñas con texto extraño y un cliente que vio pedidos ajenos al cambiar un número en la dirección web. Nadie ha ordenado esas señales ni las ha conectado con el negocio.

Solución

Un **mapa de amenazas** de la tienda para la gerencia: un glosario común, las amenazas y vulnerabilidades más probables, quiénes podrían atacar y qué impacto tendría cada caso. Será la base de la prueba en los próximos ABPRO.

Desarrollo

- 1. Glosario del equipo.** Acuerden una definición breve de ciberseguridad y sus objetivos, amenaza, vulnerabilidad, riesgo, ciberataque, ciberguerra y hacking ético, para hablar con la librería en un mismo idioma (criterio 1.1).
- 2. Inventario de la tienda.** Listen las partes de la tienda y qué datos maneja cada una: nombres, direcciones, claves, pedidos o datos de pago.
- 3. Amenazas y vulnerabilidades.** Para cada parte, identifiquen al menos una amenaza (malware, phishing o ataque de red) o una vulnerabilidad web común (por ejemplo, inyección, XSS o pérdida de control de acceso) e indiquen si su origen es interno o externo (criterio 1.2).
- 4. Cadena de un ataque.** Elijan una amenaza y describan cómo avanzaría paso a paso según la cyber kill chain, desde el reconocimiento hasta el objetivo del atacante (criterio 1.2).
- 5. Perfiles de atacante.** Describan tres atacantes posibles para la librería (por ejemplo, un ciberdelincuente que busca datos de pago, un hacktivista o un ex empleado) y comparen su motivación con la del equipo, que actúa como hacker ético de sombrero blanco (criterio 1.3).
- 6. Impacto para el negocio.** En una tabla, ejemplifiquen cinco casos de vulnerabilidad con el objetivo de seguridad que rompen, su consecuencia para la librería y una prioridad: alta, media o baja (criterio 1.4).
- 7. Resumen para el foro.** El portavoz publica en el foro del módulo un resumen de una página o un video breve con las tres amenazas más críticas. Cada equipo comenta el resumen de otro.

Roles del equipo

Cada integrante asume un rol, que rota en el ABPRO de cada aprendizaje esperado:

- **Coordinador/a:** organiza el trabajo y cuida que todos participen.
- **Analista de amenazas:** conduce el inventario, las amenazas y la cadena del ataque.
- **Analista de negocio:** conduce la tabla de impacto y las prioridades.
- **Documentador/a:** redacta la entrega.
- **Portavoz:** prepara el resumen para el foro. En equipos de 4, el documentador/a asume también este rol.

Entrega

Una entrega por equipo en esta Tarea: un PDF con el glosario, el inventario, las amenazas y vulnerabilidades, la cadena del ataque, los perfiles de atacante, la tabla de impacto, el enlace al resumen del foro y los nombres de los integrantes con su rol.